Zespołowy projekt bezpieczeństwa

Wzmocnienie bezpieczeństwa serwera Linux (Debian) poprzez audyt systemu, konfigurację SSH, firewallu i Fail2ban oraz automatyzację ustawień w sieci wirtualnej.

1. Skład zespołu i role

Imię	Rola	Zadania
Monika Campoli Nr. albumu: 163319	Lider / Analityk	Planowanie działań, koordynacja projektu, tworzenie dokumentacji i raportu końcowego.
Monika	Inżynier / Pentester	Instalacja i konfiguracja serwera, SSH, firewallu (UFW), Fail2ban, testy bezpieczeństwa, audyt systemu.
Monika	Dokumentujący / Prezenter	Zbieranie logów i screenshotów, przygotowanie raportu i prezentacji końcowej.

*Na tę chwilę pracuję sama, więc przypisałam sobie wszystkie role, jednak rozdzieliłam je, jak przy pracy zespołowej.

---

2. Temat projektu

„Wzmocnienie bezpieczeństwa serwera Linux (Debian) poprzez audyt systemu, konfigurację SSH, firewallu i Fail2ban oraz automatyzację ustawień w sieci wirtualnej.”

Temat interesuje mnie, ponieważ chcę poznać mechanizmy obrony systemów Linux i przetestować je praktycznie w bezpiecznym środowisku laboratoryjnym.

---

3. Plan działania / harmonogram prac

Etap	Działania	Narzędzia	Data
Przygotowanie środowiska	Instalacja systemu Debian Server w VirtualBox, aktualizacja systemu, utworzenie użytkownika administracyjnego.	**VirtualBox, APT**	**Do 26.03.26r**
Konfiguracja podstawowa systemu	Instalacja i konfiguracja SSH (zmiana portu, wyłączenie logowania	**SSH, UFW.**	**Do 02.04.2026**

	root), konfiguracja zapory sieciowej (UFW), aktualizacje systemu.		
Zabezpieczenia dostępu	Konfiguracja uwierzytelniania kluczami SSH, instalacja i konfiguracja Fail2ban, ograniczenie prób logowania	**SSH, Fail2ban**	
Audyt wstępny systemu	Przeprowadzenie audytu systemu narzędziem Lynis, analiza wyników, identyfikacja podatności i słabych konfiguracji	**Lynis**	**Do 16.04.2026**
Hardening systemu	Wdrożenie zaleceń z audytu: konfiguracja sysctl, wyłączenie zbędnych usług, zaostrzenie polityk bezpieczeństwa, konfiguracja uprawnień	**sysctl, systemd i inne**	**Do 30.04.2026**
Audyt końcowy i porównanie	Ponowne uruchomienie Lynis, porównanie wyników przed i po hardeningu, ocena poprawy poziomu bezpieczeństwa	**Lynis**	**Do 14.05.2026**
Analiza logów i monitorowanie	Analiza logów systemowych (logowania, blokady, zdarzenia bezpieczeństwa), weryfikacja działania Fail2ban	**journalctl, /var/log**	
Automatyzacja konfiguracji	Przygotowanie playbooka w Ansible automatyzującego konfigurację zabezpieczeń	**Ansible/opcjonalnie**	
Dokumentacja i raport	Zebranie wyników audytów, logów, opis zastosowanych zabezpieczeń oraz ich wpływu na system	**Dokumentacja**	
Prezentacja projektu	Opracowanie prezentacji przedstawiającej proces hardeningu i jego efekty	**PowerPoint**	

4. Link do repozytorium

Repozytorium GitHub:

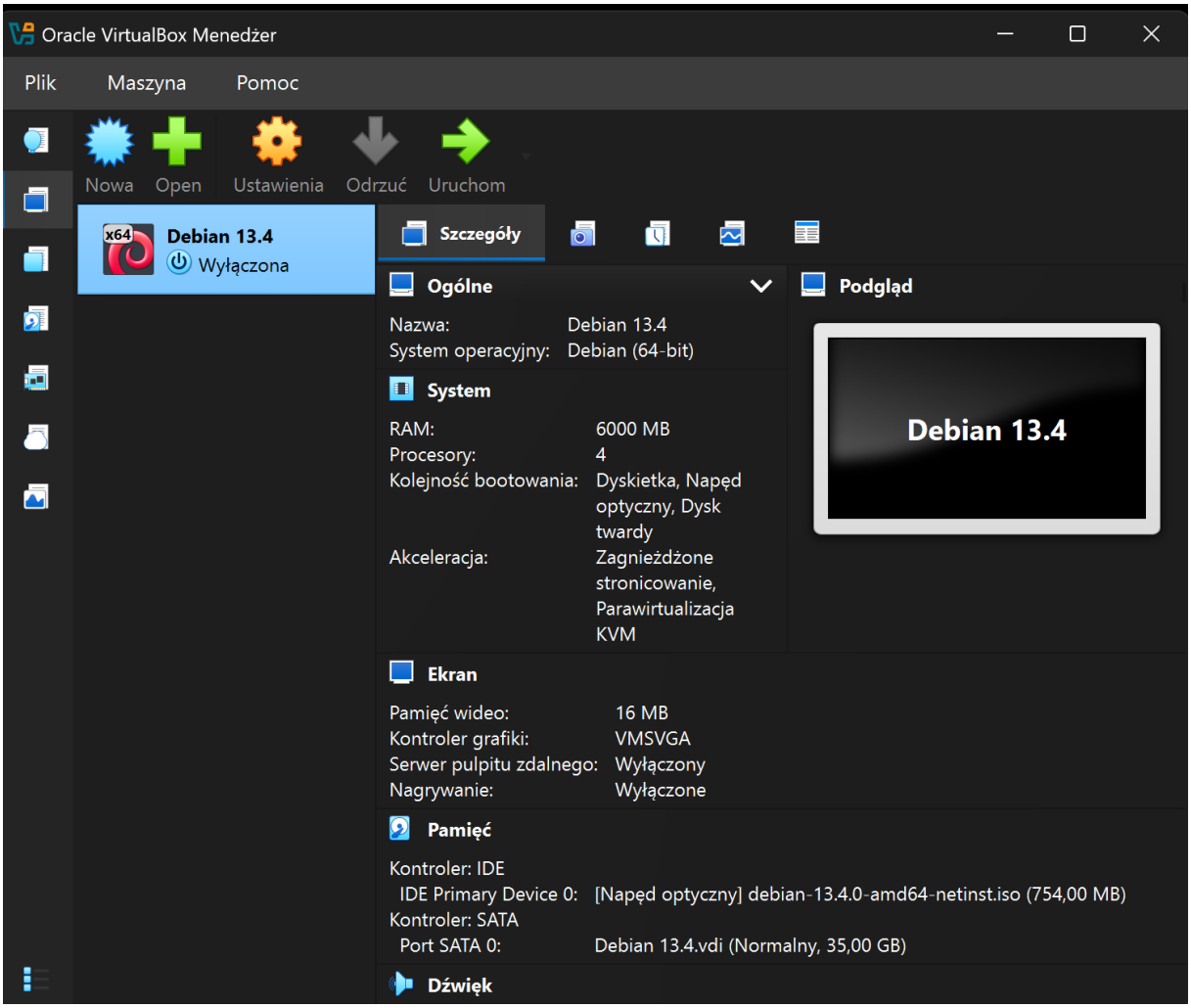
https://github.com/MCampoli/linux-hardening

Struktura repozytorium:

```
/ linux-hardening
│
├── README.md        # opis projektu, cel, użyte narzędzia
├── /docs            # raport końcowy, instrukcje, wnioski
├── /src             # konfiguracje, pliki UFW, Fail2ban, playbook Ansible
├── /results         # screenshoty, logi z testów
```

---

5. Screenshot środowiska



Sprint 1 - Pierwszy audyt bezpieczeństwa Lynis

1. Cel testu

Przeprowadzenie wstępnego audytu systemu Debian 13 w celu zidentyfikowania luk i słabych punktów konfiguracji przed rozpoczęciem procesu hardeningu.

2. Wykonane czynności

1. Instalacja systemu Debian 13 w VirtualBox (3 CPU, 4 GB RAM)

2. Aktualizacja systemu: `apt update && apt upgrade -y`

3. Instalacja narzędzia Lynis: `apt install lynis -y`

4. Wykonanie audytu: `lynis audit system`

3. Wynik audytu

Wskaźnik	Wartość
Hardening index	**63/100**
Warnings	1
Suggestions	47
Tests performed	251

4. Zidentyfikowane problemy

Problem	Poziom ryzyka	Planowana naprawa
Brak firewalla (UFW)	Wysoki	Instalacja I konfiguracja UFW
SSH na domyślnym porcie 22	Średni	Zmiana portu na 2222
Brak Fail2ban	Średni	Instalacja i konfiguracja Fail2ban
Brak automat. aktualizacji	Średni	Konfiguracja unattended-upgrades
Słabe ustawienia SSH	Średni	Hardening konfiguracji SSH

5. Wnioski

1. **System jest w stanie surowym** – wynik 63/100 wskazuje, że podstawowa konfiguracja Debiana nie jest wystarczająco zabezpieczona. Brak firewalla i domyślne ustawienia SSH to krytyczne luki.

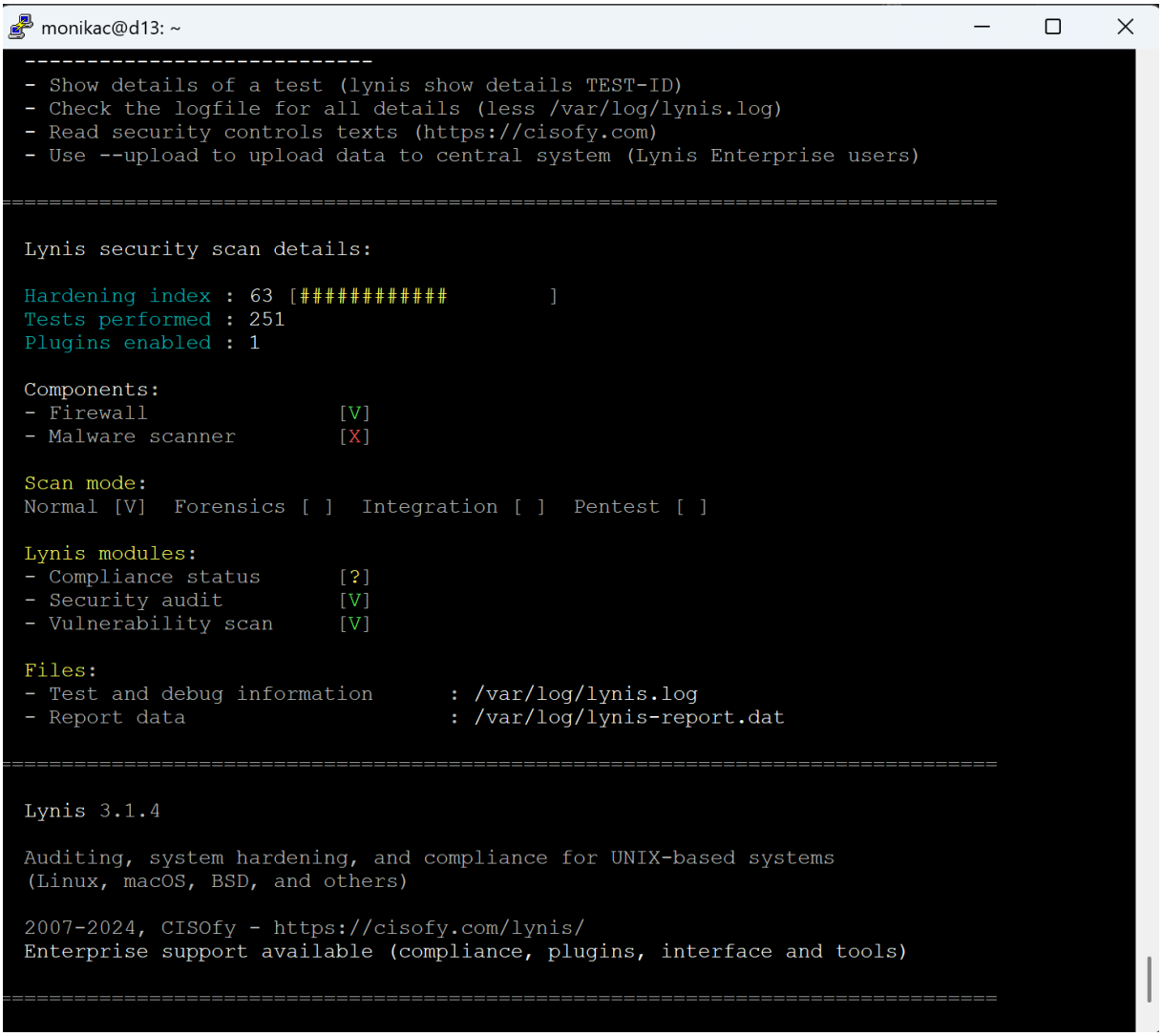
2. **Audyt potwierdza plan projektu** – wszystkie wykryte problemy są zgodne z zaplanowanymi działaniami (UFW, SSH, Fail2ban), co oznacza, że harmonogram jest trafny.

3. **Potrzeba iteracyjnego podejścia** – projekt przyjmuje iteracyjny model hardeningu, w którym każda zmiana konfiguracji jest weryfikowana poprzez ponowny audyt systemu.

6. Plan na kolejny sprint

Lp.	Zadanie	Narzędzie	Spodziewany efekt
1	| Konfiguracja firewalla	UFW	| Ochrona przed nieautoryzowanym ruchem
2	Zmiana portu SSH	Sshd_config	Zmniejszenie ryzyka ataków automatycznych
3	Hardening SSH	Sshd_config	Wyłączenie zbędnych opcji
4	Instalacja Fail2ban	Fail2ban	Automatyczna blokada IP po próbach ataku
5	Powtórny audyt	Lynis	Porównanie wyników

7. Zrzut z ekrau z wykonania testu



Sprint 2 – Hardening systemu (11 poprawek)

1. **Cel sprintu**

Wdrożenie rzeczywistych zabezpieczeń systemu na podstawie wyników audytu ze Sprintu 1 oraz podniesienie wyniku Lynis do poziomu 80+.

2. **Wprowadzone poprawki – lista**

Identyfikator	FIX-001
Opis zmiany	Instalacja i konfiguracja firewalla UFW – domyślnie blokuj przychodzące, zezwól na SSH
Test	`ufw status verbose`
Wynik	Status: active, default deny incoming, allow 2222/tcp
Pełna ścieżka mitygacji	`apt install ufw → ufw default deny incoming → ufw default allow outgoing → ufw allow 2222/tcp → ufw enable`

Identyfikator	FIX-002
Opis zmiany	Zmiana portu SSH na 2222, ograniczenie prób logowania (MaxAuthTries 3), wyłączenie X11Forwarding, AllowAgentForwarding
Test	`sshd -T | grep -E "port|maxauthtries|x11forwarding|allowagentforwarding"`
Wynik	port 2222, maxauthtries 3, x11forwarding no, allowagentforwarding no
Pełna ścieżka mitygacji	`nano /etc/ssh/sshd_config → zmiana parametrów → systemctl restart ssh → ufw allow 2222/tcp → ufw delete allow 22/tcp`

Identyfikator	FIX-003
Opis zmiany	Automatyczna blokada adresów IP po nieudanych próbach logowania
Test	`fail2ban-client status`

Wynik	Jail list: sshd
Pełna ścieżka mitygacji	`apt install fail2ban -y → systemctl enable fail2ban → systemctl start fail2ban → cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local`

Identyfikator	FIX-004
Opis zmiany	Włączenie automatycznych aktualizacji bezpieczeństwa
Test	`systemctl status unattended-upgrades`
Wynik	active (running)
Pełna ścieżka mitygacji	`apt install unattended-upgrades -y → dpkg-reconfigure unattended-upgrades (YES)`

Identyfikator	FIX-005
Opis zmiany	Dodanie parametrów zabezpieczających jądro systemu
Test	`sysctl -a | grep -E "rp_filter|log_martians|dmesg_restrict|kptr_restrict"`
Wynik	Wszystkie parametry ustawione zgodnie z wymaganiami
Pełna ścieżka mitygacji	`nano /etc/sysctl.conf → dodanie parametrów → sysctl -p`

Identyfikator	FIX-006
Opis zmiany	Ustawienie sticky bit na katalogach tymczasowych
Test	`ls -ld /tmp /var/tmp`
Wynik	drwxrwxrwt (sticky bit ustawiony)
Pełna ścieżka mitygacji	`chmod 1777 /tmp && chmod 1777 /var/tmp`

Identyfikator	FIX-007
Opis zmiany	Dodanie ostrzeżenia prawnego przed logowaniem
Test	`cat /etc/issue`
Wynik	Authorized access only. All actions are monitored.
Pełna ścieżka mitygacji	`echo "Authorized access only. All actions are monitored." > /etc/issue`

Identyfikator	FIX-008
Opis zmiany	Instalacja i konfiguracja audytu zdarzeń bezpieczeństwa
Test	`auditctl -l`
Wynik	Reguły dla /etc/passwd, /etc/shadow, /etc/ssh/sshd_config
Pełna ścieżka mitygacji	`apt install auditd -y → systemctl enable auditd → systemctl start auditd → dodanie reguł do /etc/audit/rules.d/audit.rules

Identyfikator	FIX-009
Opis zmiany	Wymuszenie polityki silnych haseł (minimum 10 znaków)
Test	`grep pam_pwquality /etc/pam.d/common-password`
Wynik	password requisite pam_pwquality.so retry=3 minlen=10
Pełna ścieżka mitygacji	`apt install libpam-pwquality -y → nano /etc/pam.d/common-password → dodanie linii`

Identyfikator	FIX-010
Opis zmiany	Pełne logowanie systemowe

Test	`systemctl status rsyslog`
Wynik	active (running)
Pełna ścieżka mitygacji	`apt install rsyslog -y → systemctl enable rsyslog → systemctl start rsyslog`

Identyfikator	FIX-011
Opis zmiany	Monitorowanie integralności plików systemowych
Test	`aide -c /etc/aide/aide.conf --check`
Wynik	Database initialized
Pełna ścieżka mitygacji	`apt install aide -y → aideinit → mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db

3. Wynik końcowy (po hardeningu)

Wskaźnik	**Wartość**
Harderning index	82/100
Warnings	0
Suggestions	31
Tests performed	262

4. Porównanie Before & After

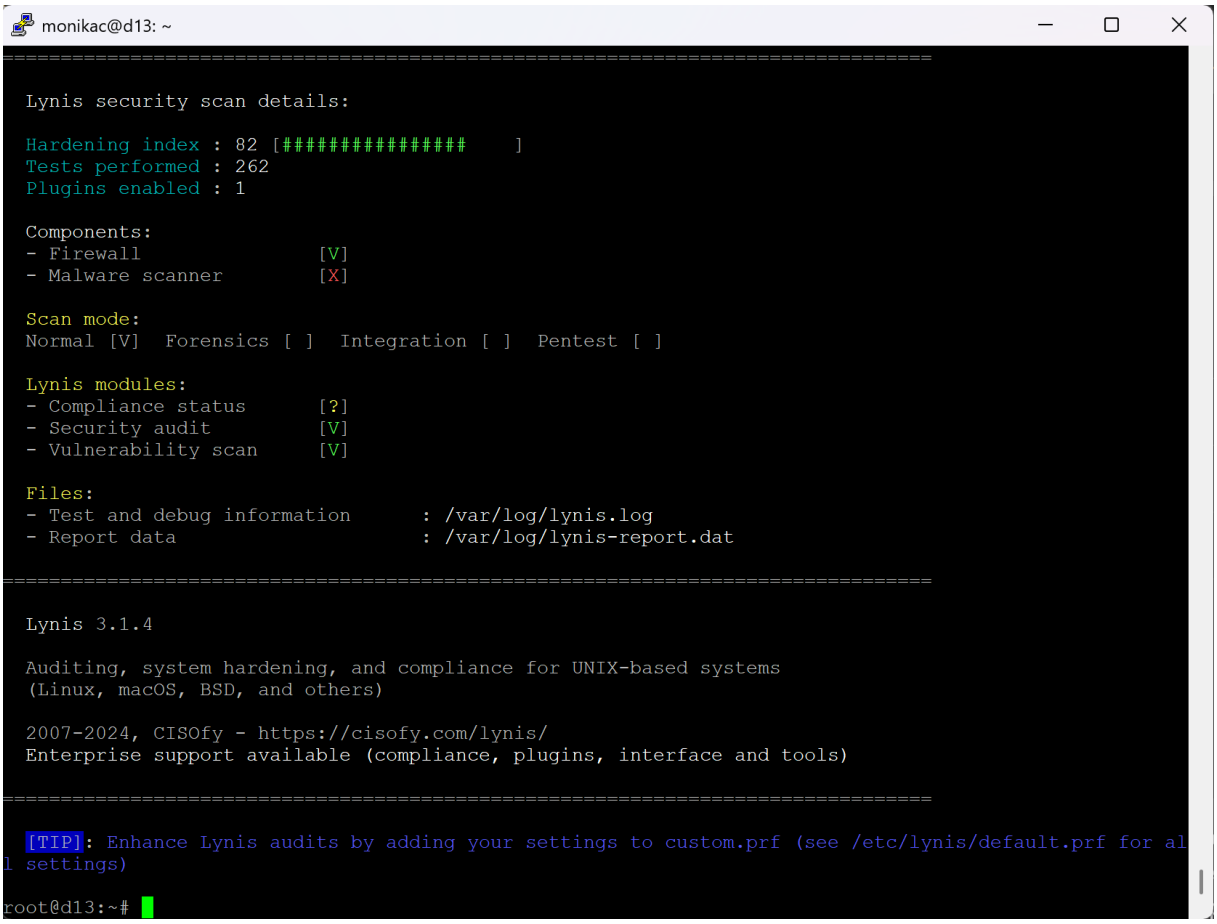
Obszar	Sprint 1	Sprint 2	Zmiana
Hardening index	63/100	82/100	+19
Warnings	1	0	
Firewall	brak	aktywny	+
Fail2ban	brak	aktywny	+
SSH port	22	2222	zmieniony

5. Wnioski końcowe

1. **Cel osiągnięty:** Hardening index wzrósł z 63 do 82 (+19 punktów).
2. **Kluczowe zmiany:** UFW, Fail2ban, SSH hardening, auditd, AIDE.

3. **System jest teraz dobrze zabezpieczony** przed typowymi atakami (brute-force, nieautoryzowany dostęp).

4. **Projekt potwierdza** że podstawowy hardening Linuxa znacząco podnosi poziom bezpieczeństwa.

5. System nadal posiada sugestie optymalizacyjne, ale brak krytycznych błędów.

6. **Zrzut z ekranu z wykonania hardeningu.**